M2 SSIR

Audit de maturité SSI

MEDICA-SERVICES · Restitution au CODIR

Team, Marc, Matteo et Bernard · 10 novembre 2026

Audit sur pièces P01 à P17 et T01 à T10. Méthode SGDN/DCSSI 2007 utilisée comme référence pédagogique, sans valeur de certification. Cas fictif.

Où en est MEDICA-SERVICES

Niveau adéquat : 4 sur 5

Somme des maxima 10. Données de santé, sécurité de patients chez 12 clients, reprise contractuelle en 8 h.

Niveau démontré : 1 à 2

Aucun processus au niveau 3. Écart de 2 à 3 niveaux.

Une affirmation contredite (MFA) et une non démontrée (tests de restauration), P17.

Processus	Démontré	Cible
Stratégie	1	4
Risques	1	4
Règles	2	4
Supervision	1	4
Conception	2	4
Réalisation	1	4
Exploitation	2	4

Trois risques majeurs

R01 · Compte à privilèges détourné

Score 12. 4 comptes privilégiés sur 10 non enrôlés MFA, dont un administrateur de domaine sans activité documentée depuis 2025 (T03). Modification non autorisée de l'AD et des serveurs.

R02 · Reprise au-delà de 8 h

Score 12. Rançongiciel ou panne. Restaurations peu éprouvées et sauvegardes joignables depuis tous les postes.

R03 · Données patients via APP01

Score 8. Correctif critique manquant, hôte en retard de 74 jours, sans exception. Impact maximal, levier rapide. Application non exposée directement.

Trois constats décisifs

Alerte AL-1048 sans examen tracé

9 octobre, 00:13 à 00:22 UTC. Compte admin-old connecté au VPN après 3 échecs, ajout à Server-Admins. Fermeture automatique 24 h plus tard, aucun ticket. À investiguer, pas une intrusion prouvée (T07, T08).

Restauration testée sur 2 services sur 9

La DG déclare des tests trimestriels de toutes les restaurations. Deux PV cités, contenu non communiqué. RTO de 8 h non démontré, RPO non fourni (T09, P17).

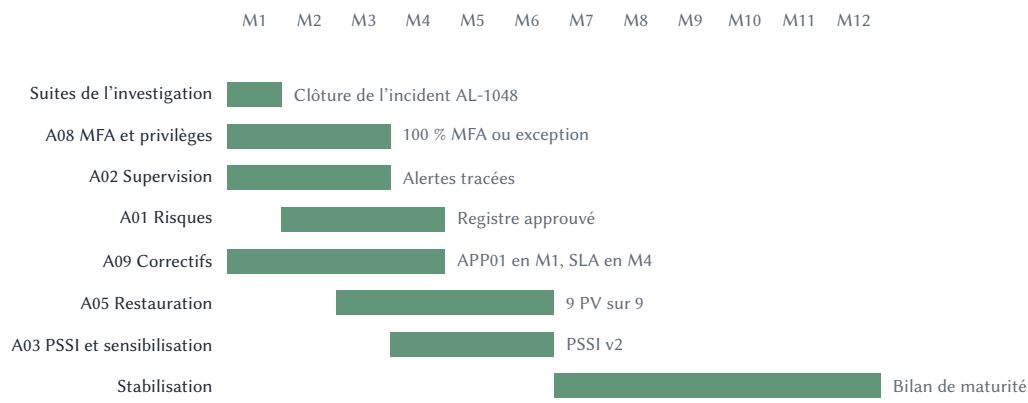
MFA à 60 % des comptes privilégiés

La DSI déclare 100 %. Export : 6 comptes enrôlés sur 10. Prestataire et compte de sauvegarde sans second facteur (T03, T04, P17).

Trois décisions demandées

	Décision	Effet attendu
1	Mandater dès aujourd'hui l'investigation d'AL-1048 et les mesures conservatoires (admin-old, FW-31, FW-17)	Événement qualifié, accès à risque fermés sous un mois
2	Engager 116 000 € sur 120 000 € pour six actions (A01, A02, A03, A05, A08, A09)	Les 7 processus au niveau 2 démontré à 12 mois, marge 4 000 €
3	Accepter par écrit pour 12 mois les risques résiduels des mesures différées, dont la segmentation (A10) et la standardisation (A04)	R04, R06 et part de R02 suivis et réexaminés au bilan annuel

Feuille de route sur 12 mois



Hypothèse : décision du CODIR à la mi-novembre 2026, M1 = décembre 2026. Mesures conservatoires engagées dès la remise du rapport. Chaque palier est validé par une preuve de clôture, non par déclaration.